

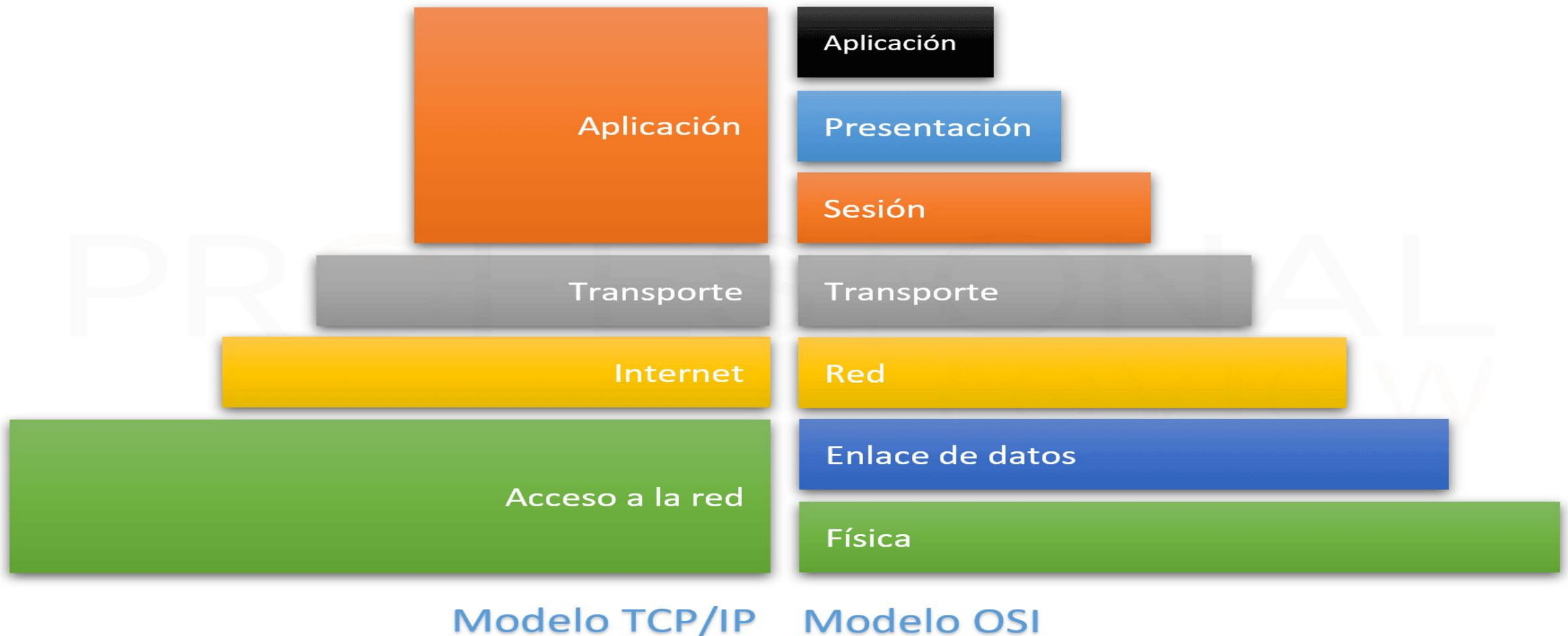
Seguridad en la red corporativa

Seguridad y Alta Disponibilidad

PROTOCOLO TCP/IP

- El Protocolo de control de transmisión (Transmission Control Protocol, TCP) es un estándar de comunicaciones que permite que los programas de aplicaciones y dispositivos informáticos intercambien mensajes a través de una red. Está diseñado para enviar paquetes a través de Internet y garantizar la entrega exitosa de datos y mensajes a través de redes.

PROTOCOLO TCP/IP



Ataques en redes TCP/IP



Suplantación de identidad (spoofing)

Este tipo de ataque implica que un atacante falsifique la identidad de un dispositivo en la red, utilizando la dirección IP de otro dispositivo legítimo.

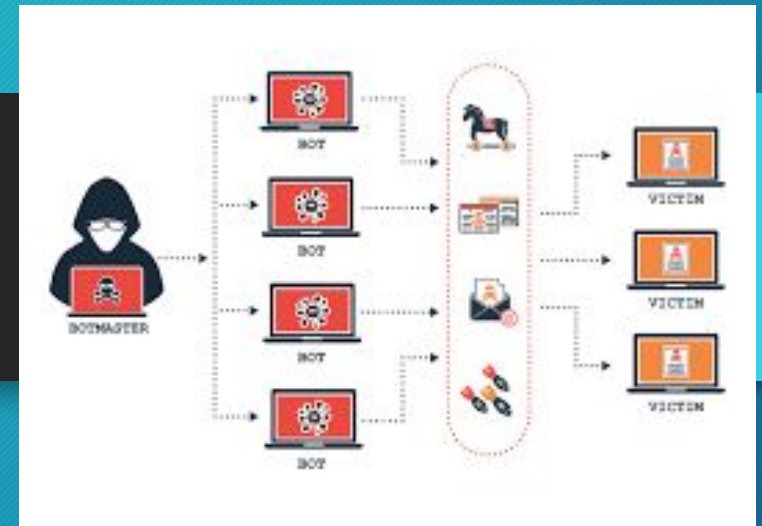
- **Riesgos:** Permite a los atacantes interceptar información, ejecutar comandos en la red y obtener acceso no autorizado a sistemas internos.
- **Mitigación:** Configurar filtros de IP y utilizar autenticación adicional en los servicios críticos.

Ataques en redes TCP/IP

Ataques de denegación de servicio (DoS)

Los ataques DoS tienen como objetivo hacer que los recursos de red, como servidores o aplicaciones, sean inaccesibles al saturarlos con tráfico malicioso.

- **Riesgos:** Provoca interrupciones en el servicio, pérdida de productividad y posibles pérdidas económicas.
- **Mitigación:** Implementación de firewalls con filtrado de tráfico y el uso de sistemas de detección y prevención de intrusiones (IDS/IPS).



Ataques en redes TCP/IP

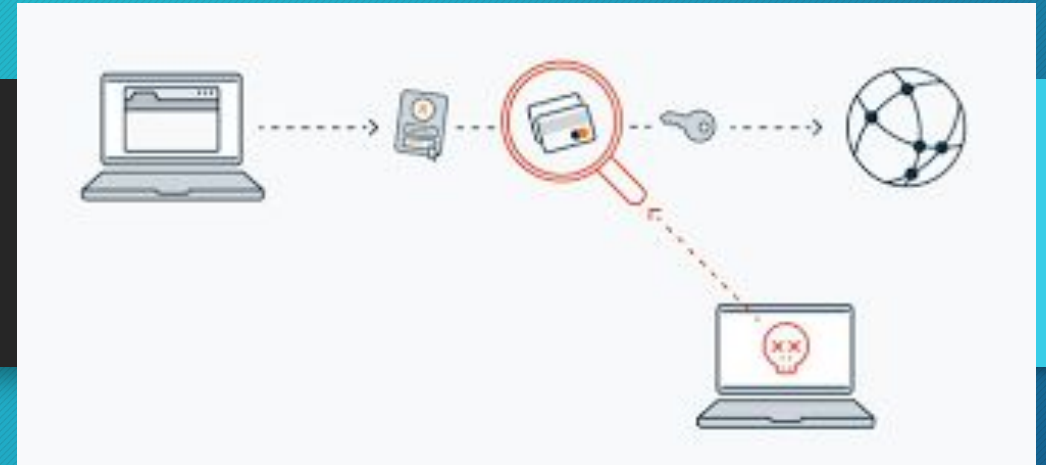


Inyección de paquetes

La inyección de paquetes implica que un atacante inserta paquetes de datos falsos en la red para interrumpir la comunicación o engañar a los sistemas.

- **Riesgos:** Puede llevar a la alteración de datos y a la corrupción de sesiones activas entre dispositivos.
- **Mitigación:** Usar autenticación de paquetes y protocolos seguros como IPSec.

Ataques en redes TCP/IP



Sniffing de red

En el sniffing, un atacante utiliza herramientas para interceptar y capturar el tráfico de red.

- **Riesgos:** Exposición de datos sensibles como credenciales, información personal y comunicaciones internas.
- **Mitigación:** Uso de cifrado en las comunicaciones, como TLS para tráfico web y SSH para administración remota.

Ataques en redes TCP/IP

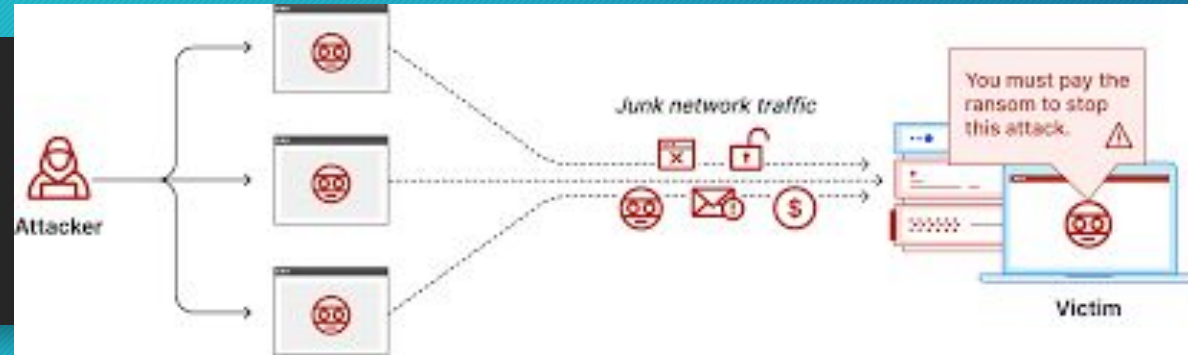


Vulnerabilidades en servicios específicos

Algunos servicios o protocolos específicos dentro del TCP/IP pueden tener fallos explotables, como FTP, Telnet o HTTP.

- **Riesgos:** Exponen a las organizaciones a riesgos que pueden ser utilizados para obtener acceso a sistemas.
- **Mitigación:** Actualización constante de servicios, aplicación de parches y uso de alternativas más seguras (como SFTP en lugar de FTP).

Ataques en redes TCP/IP



Ataques de enrutamiento malicioso

Este tipo de ataque se basa en manipular la información de enrutamiento para redirigir el tráfico a través de un dispositivo malicioso o hacer que no llegue a su destino.

- **Riesgos:** Permite a los atacantes interceptar tráfico, causar interrupciones y crear vulnerabilidades adicionales.
- **Mitigación:** Utilizar protocolos de enrutamiento seguros y autenticación en los dispositivos de red.

Ataques en redes TCP/IP

Escucha pasiva

En una escucha pasiva, un atacante se limita a capturar el tráfico sin modificarlo, para obtener información valiosa sin ser detectado.

- **Riesgos:** Riesgo de filtración de información confidencial sin que los usuarios o administradores lo noten.
- **Mitigación:** Cifrado de datos en tránsito y segmentación de red para limitar el acceso a los datos.



Medidas de seguridad en redes TCP/IP

Autenticación y Control de Acceso

- **Contraseñas fuertes:** Establecer políticas que requieran contraseñas complejas y seguras.
- **Autenticación de dos factores (2FA):** Utilizando un segundo factor, como una aplicación en el móvil o un token físico, para reforzar la autenticación.
- **Certificados digitales:** Implementar certificados que autenticquen a usuarios y dispositivos.
- **Herramientas:**
 - **FreeRADIUS:** Puede usarse en el laboratorio para gestionar autenticación centralizada y control de acceso. Es ideal para pruebas de autenticación con certificados digitales o 2FA.
 - **OpenSSL:** Para crear certificados digitales y probar cómo se pueden usar en la autenticación en servidores.

Medidas de seguridad en redes TCP/IP

- **Cifrado y Privacidad de Datos**

- **SSL/TLS:** Usar TLS (y evitar SSL por sus vulnerabilidades) en servicios web y otros sistemas para proteger la información transmitida.
- **VPN (Virtual Private Network):** Configuración de redes privadas para que las comunicaciones externas a través de Internet estén cifradas.

- **Herramientas:**

- **Wireshark:** Permite analizar el tráfico en red y comprobar que los datos están cifrados cuando se utiliza TLS.
- **OpenVPN:** Herramienta gratuita para establecer redes VPN y probar conexiones cifradas.
- **OpenSSL:** Para generar certificados y aplicar cifrado en servicios web simulados.

Medidas de seguridad en redes TCP/IP

- **Firewalls y Sistemas de Detección de Intrusos (IDS)**
 - **Firewalls:** Configurar reglas que limiten el acceso a la red en función de direcciones IP, puertos y protocolos.
 - **IDS:** Monitorear y alertar de patrones sospechosos, como intentos de acceso no autorizado o tráfico anómalo.
- **Herramientas:**
 - **pfSense:** Firewall basado en FreeBSD que puede instalarse en un entorno de laboratorio. Permite gestionar reglas de firewall avanzadas.
 - **Snort o Suricata:** IDS de código abierto que puede analizar el tráfico en tiempo real y detectar patrones de ataque.

Medidas de seguridad en redes TCP/IP

- **Prevención de Ataques de Denegación de Servicio (DoS)**
 - **Límites de ancho de banda:** Limitar la cantidad de solicitudes que un servidor puede manejar por segundo.
 - **Filtrado de direcciones IP:** Bloquear IPs que generen tráfico sospechoso o excesivo.
 - **Sistemas de detección y prevención de intrusos:** Identificar ataques DoS y bloquearlos antes de que saturen el sistema.
- **Herramientas:**
 - **iptables:** En Linux, permite configurar reglas de tráfico y limitar el ancho de banda de ciertas IPs.
 - **Fail2Ban:** Bloquea direcciones IP tras varios intentos de conexión fallidos, útil para prevenir ataques de fuerza bruta o DoS a nivel de autenticación.
 - **Hping3:** Permite simular ataques DoS de baja intensidad en un entorno controlado para probar medidas de defensa.

Medidas de seguridad en redes TCP/IP

- **Gestión y Monitoreo de la Red**

- **Aplicación de parches:** Mantener el software actualizado y libre de vulnerabilidades conocidas.
- **Monitoreo de tráfico:** Analizar el flujo de datos para identificar patrones sospechosos.
- **Gestión de dispositivos:** Controlar los dispositivos conectados a la red y sus permisos.

- **Herramientas:**

- **Nagios o Zabbix:** Soluciones de monitoreo que ofrecen alertas en tiempo real sobre el estado de la red y sus dispositivos.
- **Wireshark:** Para análisis de tráfico profundo, identificando picos inusuales o tráfico anómalo.
- **OpenVAS:** Escáner de vulnerabilidades que permite evaluar qué parches o configuraciones pueden ser necesarios para reducir riesgos.

Seguridad en los servicios de red

Fugas de Información Confidencial

- Los servicios de red pueden transmitir o almacenar datos sensibles, lo que implica que una mala configuración o una vulnerabilidad en los protocolos de comunicación puede exponer esta información.

Medidas de seguridad :

- **Cifrado de extremo a extremo:** Utilizar SSL/TLS en servicios como el correo electrónico o la transferencia de archivos para proteger los datos en tránsito.
- **Herramientas de monitoreo:** Implementar sistemas que monitoreen el tráfico de red en busca de datos confidenciales en canales no seguros.
- **Control de acceso:** Limitar el acceso a servicios y datos sensibles a usuarios autorizados únicamente, mediante autenticación fuerte y control de permisos.

Seguridad en los servicios de red

Ataques de Phishing e Ingeniería Social

- **Riesgo:** Los ataques de phishing y de ingeniería social buscan engañar a los usuarios para que revelen información confidencial o realicen acciones no deseadas.

Medidas de seguridad :

- **Formación de usuarios:** Educar a los empleados sobre cómo identificar correos electrónicos y mensajes sospechosos. En entornos de laboratorio, se pueden realizar simulaciones de phishing para que los estudiantes practiquen cómo detectarlos.
- **Filtros de contenido:** Implementar filtros de correo y reglas que identifiquen y bloqueen correos electrónicos sospechosos. Herramientas como **SpamAssassin** pueden ser configuradas para analizar y clasificar correos maliciosos.
- **Autenticación avanzada:** Utilizar autenticación multifactor (MFA) para reducir el riesgo de que las cuentas comprometidas puedan ser utilizadas fácilmente.

Seguridad en los servicios de red

Malware y Ransomware

- **Riesgo:** Los servicios de red, como el correo electrónico y las descargas de archivos, son vectores comunes para la distribución de malware y ransomware, que pueden cifrar datos o causar daños a los sistemas.

Medidas de seguridad:

- **Antivirus y antimalware:** Configurar soluciones antivirus en los sistemas de la red para escanear archivos adjuntos de correo y descargas. En laboratorios de ASIR, se pueden utilizar herramientas como **ClamAV** para enseñar cómo funcionan las detecciones de malware.
- **Políticas de descarga seguras:** Restringir las descargas de archivos de fuentes no confiables y aplicar filtros que analicen los archivos antes de permitir su acceso.
- **Backups regulares:** Realizar copias de seguridad frecuentes que permitan la recuperación en caso de un ataque de ransomware.

Seguridad en los servicios de red

Acceso No Autorizado

- **Riesgo:** Un atacante podría intentar acceder a los servicios de red mediante técnicas como la fuerza bruta, el uso de contraseñas débiles o la explotación de vulnerabilidades.

Medidas de seguridad:

- **Contraseñas seguras y MFA:** Exigir contraseñas fuertes y habilitar autenticación multifactor para todos los servicios críticos.
- **Sistemas de detección y bloqueo:** Herramientas como Fail2Ban pueden bloquear direcciones IP después de varios intentos de acceso fallidos, reduciendo el riesgo de ataques de fuerza bruta.
- **Parches y actualizaciones:** Mantener los servicios de red y el software actualizado para reducir la posibilidad de que un atacante explote vulnerabilidades conocidas.

Seguridad en los servicios de red

Interrupción del Servicio

- **Riesgo:** La disponibilidad de los servicios puede verse afectada por ataques DoS, configuraciones erróneas o fallos en el sistema, lo que impacta la productividad de la organización.

Medidas de seguridad:

- **Balanceo de carga y redundancia:** Implementar sistemas de balanceo de carga y servidores redundantes para minimizar el impacto de un ataque DoS o una falla técnica.
- **Límites de tráfico y mitigación de DoS:** Configurar reglas en el firewall para limitar el tráfico inusual y utilizar herramientas de mitigación de DoS en caso de que se detecte un ataque. Firewalls como pfSense permiten configurar reglas de limitación de tráfico.
- **Monitoreo y alertas:** Implementar sistemas de monitoreo como Nagios o Zabbix que alerten ante posibles problemas de servicio y permitan a los administradores reaccionar rápidamente.

Seguridad en los servicios de red

Seguridad en los accesos de red.

- Autenticación sólida

La autenticación sólida implica verificar la identidad de los usuarios antes de permitir el acceso. Esto se puede hacer mediante contraseñas robustas, autenticación de dos factores (2FA), certificados digitales o incluso biometría en algunos casos.

- Contraseñas robustas
- Autenticación de dos factores (2FA)
- Certificados digitales

- Autorización adecuada

La autorización adecuada implica que los usuarios solo tengan los privilegios necesarios para realizar sus tareas. Esto reduce el riesgo de acceso no autorizado o abuso de privilegios.

- Principio de mínimo privilegio: Asignar a los usuarios únicamente los permisos necesarios para realizar sus funciones.
- Roles y grupos: Utilizar roles o grupos en sistemas como Active Directory para controlar los niveles de acceso.

Seguridad en los servicios de red

Seguridad en los accesos de red.

- Gestión de Contraseñas Seguras
 - Una buena gestión de contraseñas reduce el riesgo de acceso no autorizado. Esto incluye la creación de contraseñas seguras, la rotación periódica y la eliminación de contraseñas por defecto.
 - Política de contraseñas
 - Cambios periódicos
 - Evitar contraseñas por defectos y repeticiones
- Monitorización y Registro de Eventos
 - La monitorización y registro de eventos de acceso permite identificar actividades sospechosas y posibles intentos de acceso no autorizado. Esto es clave para la detección temprana de amenazas y la respuesta ante incidentes.
 - o Registros detallados
 - o Alertas en tiempo real
 - o Revisión regular de logs

Seguridad en los servicios de red

Arranque de servicios

Deshabilitación de Servicios Innecesarios

- Al deshabilitar los servicios que no se usan o que no son esenciales, se reduce la superficie de ataque al limitar los puntos de entrada para los atacantes.
 - Auditoría de servicios:.
 - Uso de herramientas de gestión de servicios

Evaluación de Servicios Críticos

- Identificar los servicios críticos que son fundamentales para el funcionamiento del sistema y garantizar que estén protegidos y bien configurados.
 - Identificación de servicios críticos
 - Configuración de los servicios de arranque

Seguridad en los servicios de red

Arranque de servicios

Configuración Segura de Servicios

- Configurar de manera segura los servicios que se ejecutan en el sistema, limitando el acceso a usuarios específicos y ajustando los parámetros de seguridad.
 - Revisión de permisos
 - Configuración de seguridad

Monitorización y Detección de Cambios

- Monitorizar los servicios y detectar cambios en su configuración o estado permite una respuesta rápida en caso de incidentes.
 - Registro de eventos
 - Alertas y monitorización en tiempo real

Puertos

Puertos Bien Conocidos

- Los puertos bien conocidos (del 0 al 1023) están reservados para servicios específicos con asignaciones estándar, como HTTP en el puerto 80 y HTTPS en el 443. Los atacantes suelen buscar estos puertos para identificar servicios vulnerables y lanzar ataques específicos.

Puertos Abiertos y Cerrados

- Los puertos abiertos son aquellos que aceptan conexiones entrantes y están disponibles para comunicación externa, mientras que los puertos cerrados no están accesibles desde el exterior.

Puertos

Firewalls y Reglas de Filtrado

- Los firewalls son esenciales para gestionar el tráfico que entra y sale de la red. Permiten configurar reglas que controlan el acceso según el puerto y el origen o destino de la conexión, protegiendo contra accesos no autorizados.

Escaneo de Puertos

- El escaneo de puertos es una técnica utilizada tanto por administradores de red como por atacantes para descubrir qué puertos están abiertos en un sistema. Identificar puertos abiertos puede revelar servicios y aplicaciones vulnerables.

Puertos

Gestión de Puertos y Servicios

- La gestión adecuada de los puertos implica mantener los servicios actualizados, aplicar parches de seguridad, y configurar permisos y privilegios. Esto asegura que los servicios que se ejecutan en los puertos estén protegidos.

Segmentación de Red

- La segmentación de red consiste en dividir la red en subredes más pequeñas para limitar el tráfico entre segmentos, lo que reduce el riesgo de propagación en caso de que un segmento sea comprometido.

Descripción general de protocolos seguros a diferentes niveles

IPsec (Internet Protocol Security)

Es un conjunto de protocolos y estándares de seguridad que protege las comunicaciones en redes IP. Sus principales funciones son la autenticación, el cifrado y la integridad de los datos. IPsec es muy común en redes privadas virtuales (VPN), proporcionando un túnel seguro entre dos redes o dispositivos.

Descripción general de protocolos seguros a diferentes niveles

IPsec (Internet Protocol Security)

Características principales:

- **Cifrado de datos:** Protege los datos contra interceptación.
- **Integridad:** Verifica que los datos no han sido alterados.
- **Autenticación:** Asegura que los datos provienen de una fuente confiable.
- **Protección contra ataques de replay:** Previene que un atacante reutilice paquetes interceptados.
- **VPN:** Configuración de VPN para proteger la transmisión de datos confidenciales.

Descripción general de protocolos seguros a diferentes niveles

SSL/TLS (Secure Sockets Layer / Transport Layer Security)

SSL y su sucesor TLS son protocolos de seguridad que se utilizan para establecer conexiones seguras a través de Internet. Proporcionan cifrado, autenticación y verificación de la integridad de los datos, siendo fundamentales en la seguridad web, especialmente a través del protocolo HTTPS.

Descripción general de protocolos seguros a diferentes niveles

SSL/TLS (Secure Sockets Layer / Transport Layer Security)

Características principales: **Cifrado de comunicaciones:** Protege los datos transmitidos entre el cliente y el servidor.

- **Autenticación de servidores:** Permite que el cliente verifique la identidad del servidor.
- **Integridad de datos:** Detecta modificaciones o corrupción durante la transmisión.
- **Compatibilidad con versiones y algoritmos:** Soporta varias versiones y algoritmos (TLS 1.2, TLS 1.3).
- **Aplicación en seguridad web:** Es la base de HTTPS y se utiliza para correos electrónicos y conexiones VPN.

Descripción general de protocolos seguros a diferentes niveles

PGP (Pretty Good Privacy)

PGP es un programa de criptografía de clave pública ampliamente utilizado para proteger la información en comunicaciones electrónicas, especialmente en correos electrónicos. Utiliza criptografía de clave pública para cifrar los datos y firmas digitales para autenticación.

- **Características principales:**

- **Cifrado de extremo a extremo:** Solo los destinatarios autorizados pueden leer el contenido.
- **Criptografía de clave pública:** Permite que cualquiera pueda cifrar mensajes para un destinatario específico sin conocer su clave privada.
- **Firma digital:** Garantiza la autenticidad del remitente mediante una firma creada con la clave privada.
- **Aplicaciones diversas:** Compatible con clientes de correo como Thunderbird y Outlook.
- **Estándar abierto:** Revisión y mejora continua por la comunidad de seguridad.

Descripción general de protocolos seguros a diferentes niveles

S/MIME (Secure / Multipurpose Internet Mail Extensions)

Es un estándar de seguridad que se utiliza para proteger la comunicación por correo electrónico. Proporciona cifrado de mensajes y firma digital, asegurando la confidencialidad y autenticidad en los correos electrónicos. Es ampliamente adoptado en entornos corporativos.

- **Características principales:**

- **Cifrado de mensajes:** Los mensajes se cifran antes de ser enviados.
- **Firma digital:** La firma asegura la autenticidad del remitente.
- **Certificados digitales:** Verifican la identidad de los remitentes y destinatarios.
- **Interoperabilidad:** Compatible con varios clientes de correo (Outlook, Thunderbird, Apple Mail).
- **Uso en entornos empresariales:** Amplia adopción en organizaciones que requieren alta seguridad en el correo electrónico.